

Manual 13 - SOX ITGC / ICFR Controlled Implementation

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: bd95c57ec7c4f55f6c2c8720afa1ad9df4c16679 | Language: en | SOX/SEC/PCAOB authority boundaries retained.

Legal and audit boundary: This manual provides practical ICFR technology-control implementation guidance. It does not provide organization-specific legal advice, determine materiality, filer status, exemptions, deficiency classification, auditor scope, or guarantee SOX compliance. Current authoritative sources and competent human judgment remain controlling.

Implementation paths

Manual 13 — SOX ITGC / ICFR Implementation Paths

These paths support practical adoption. They do not change SOX, SEC, or PCAOB requirements and do not determine materiality, filer status, audit scope, or legal conclusions.

Essential path

Establish the ICFR technology scope, map significant processes and systems, assign control ownership, implement core access/change/operations controls, define evidence, perform periodic management testing, track deficiencies, and retain source/evidence traceability.

Manual 03 memory graphic 1

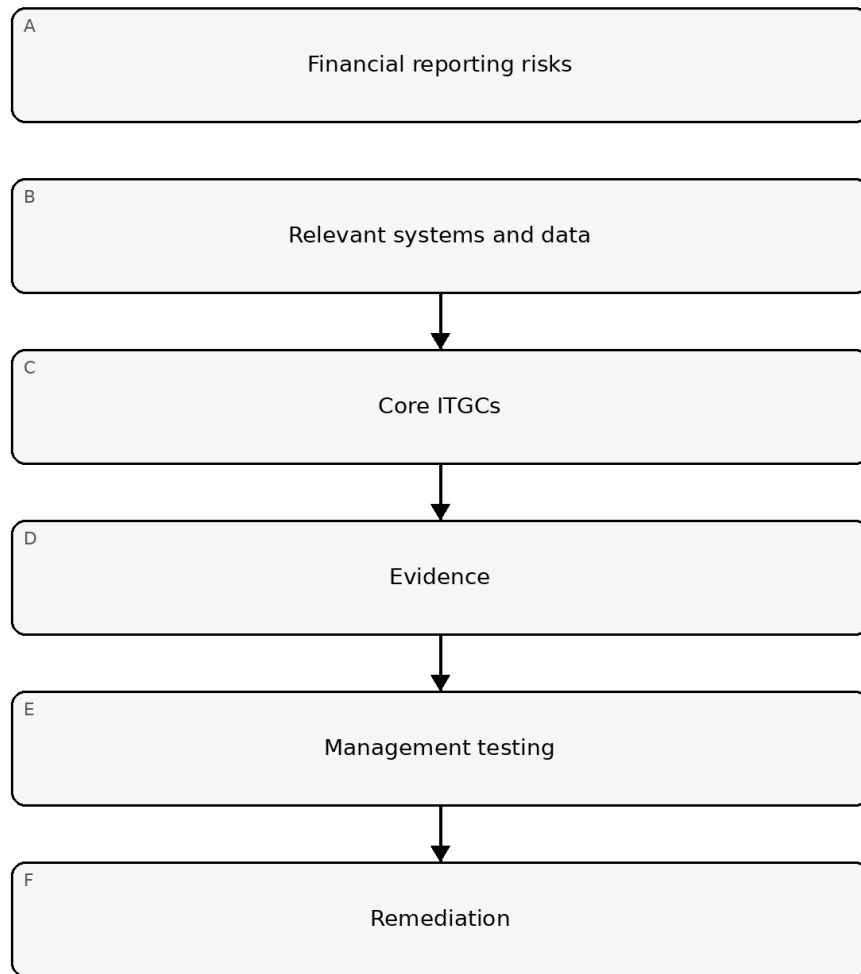


Figure 1. Implementation memory graphic

Accessible explanation: Start with financial-reporting risks, identify the supporting technology, operate the core ITGCs, retain evidence, test the controls, and remediate failures.

Structured path

Add assertion-level linkage, population completeness controls, standardized test procedures, IPE/report validation, service-organization governance, formal change-triggered reassessment, and integrated management certification support.

Manual 03 memory graphic 2

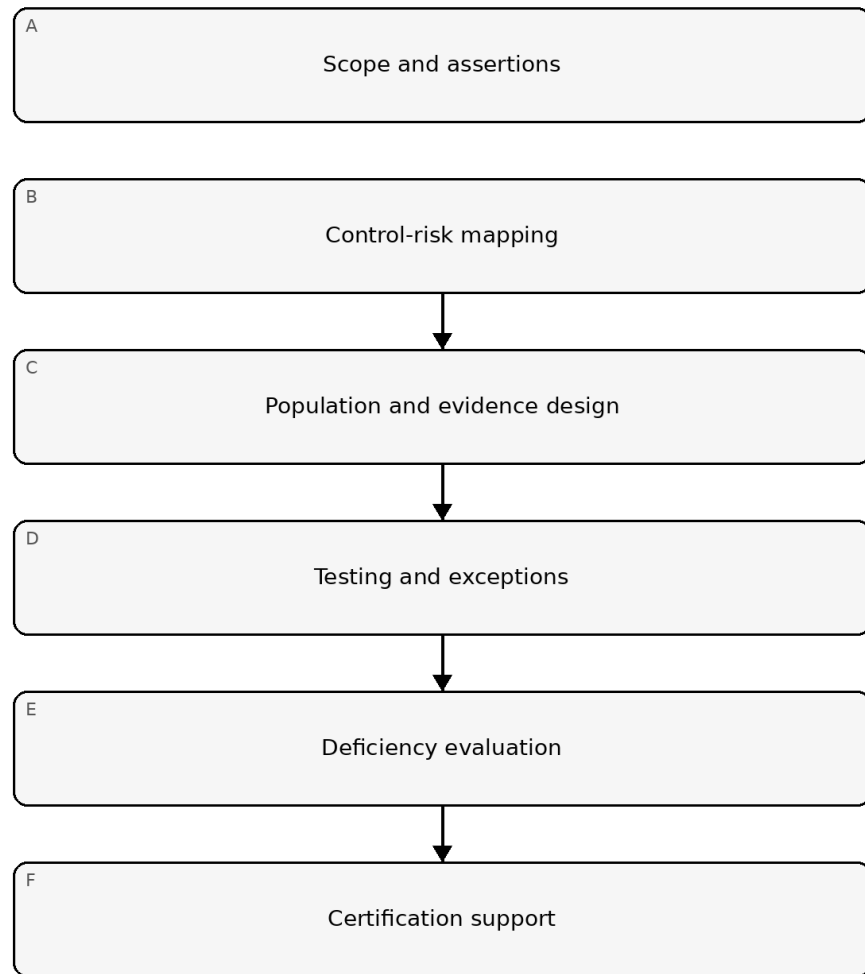


Figure 2. Implementation memory graphic

Accessible explanation: Structured implementation connects scope and assertions to explicit control-risk mappings, validates populations and evidence, manages testing exceptions, escalates deficiencies, and feeds certification support.

Enhanced path

Add continuous monitoring, evidence automation with provenance, configuration and identity analytics, control dependency graphs, automated change detection, cloud/SaaS posture integration, AI/automation governance for financially relevant processes, and risk-triggered reassessment.

Manual 03 memory graphic 3

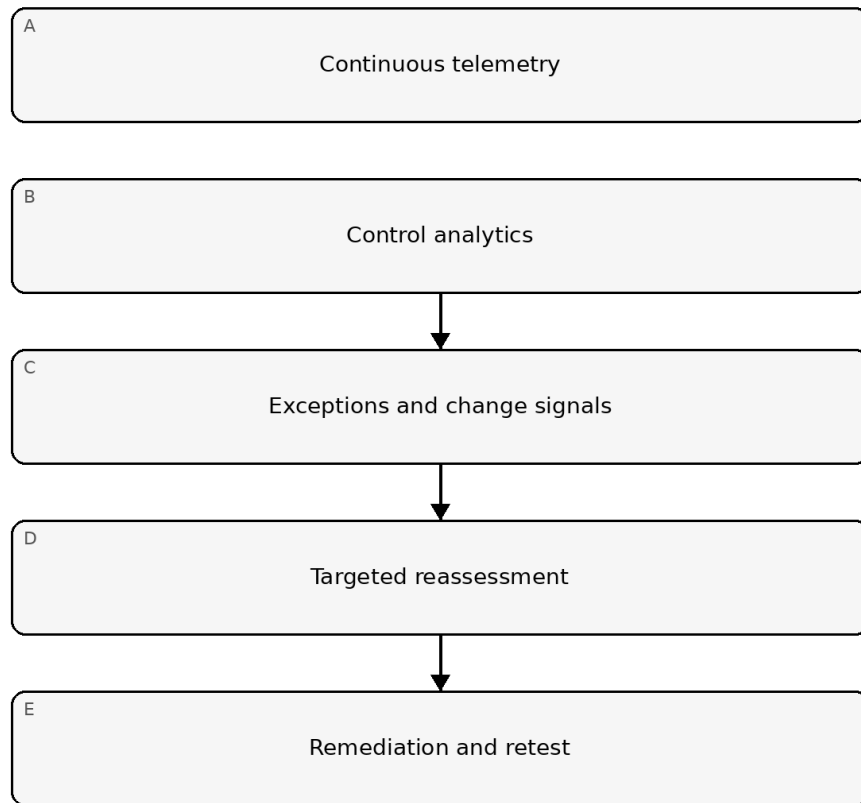


Figure 3. Implementation memory graphic

Accessible explanation: Enhanced implementation continuously monitors control signals, analyzes exceptions and changes, triggers targeted reassessment, and cycles remediation and retesting back into monitoring.

Release boundary

The controlled English source governs meaning. es-419 and pt-BR editions are machine-assisted drafts until competent semantic review is recorded. All publication artifacts require accessibility/visual review, exact hashes, source verification, workflow-security checks, provenance, and changed-scope reconciliation before release.

Controlled 32-chapter manual

Chapter 1 — Purpose and operating boundary

This manual translates SOX/ICFR technology-control obligations into a practical governance and evidence model. It distinguishes binding law and SEC rules, PCAOB auditor requirements, regulator guidance, and optional implementation frameworks. Use the manual to design, operate, test, evidence, remediate, and reassess technology controls that support internal control over financial reporting (ICFR). Do not use it to make an organization-specific materiality, filer-status, exemption, or legal conclusion without competent judgment.

Chapter 2 — SOX Sections 302 and 404 context

Section 302 executive certifications and Section 404 management assessment/reporting create different but related governance expectations. Establish a responsibility map showing management certification support, control ownership, disclosure-process inputs, ICFR evaluation responsibilities, and escalation routes. Technology teams should understand which systems, reports, data flows, and automated controls materially support financial reporting and which cybersecurity activities are outside ICFR scope unless they affect those dependencies.

Chapter 3 — Management versus external-auditor responsibilities

Management owns the design, operation, assessment, and documentation of ICFR. The external auditor independently evaluates ICFR when an integrated audit or attestation is required. Keep management testing distinct from auditor procedures. Evidence prepared by management should be reproducible and sufficiently complete to support management conclusions without being tailored merely to satisfy an expected audit sample.

Chapter 4 — Scope and applicability

Define the reporting entity, relevant accounts and disclosures, significant processes, financially relevant applications, interfaces, infrastructure, service organizations, reports, spreadsheets, and data stores. Document why each technology component is in or out of ICFR scope. Reassess scope after acquisitions, system migrations, major releases, cloud moves, new outsourcing arrangements, material process redesigns, or significant deficiencies.

Chapter 5 — Financial-statement risk and assertion linkage

Technology controls should trace to financial-reporting risks rather than generic control catalogs. Link business-process risks to relevant assertions, significant accounts/disclosures, automated controls, reports, interfaces, and IT dependencies. Each ITGC should explain how failure could affect completeness, accuracy, authorization, valuation, occurrence, cutoff, presentation, or another relevant financial-reporting objective.

Chapter 6 — Governance and accountability

Assign executive accountability, process owners, control owners, system owners, evidence custodians, testers, reviewers, and remediation owners. Define segregation-of-duties expectations between control operation and independent evaluation. Establish escalation thresholds for failed controls, repeated exceptions, overdue remediation, unresolved access conflicts, failed jobs, unauthorized changes, and unreliable reports.

Chapter 7 — Entity-level technology controls

Entity-level controls include governance over access, change, operations, security, risk assessment, monitoring, and financial-system oversight. Evaluate whether these controls operate with enough precision to reduce risks at lower levels. Broad policy statements alone are not sufficient evidence of operating effectiveness; the organization should demonstrate governance actions, monitoring, decisions, and follow-through.

Chapter 8 — ITGC domains and ICFR relevance

Organize ITGCs around access to programs and data, program changes, program development/acquisition, and computer operations, while adding interfaces, IPE/reports, and modern service dependencies where needed. A control belongs in ICFR only when it supports a financially relevant dependency. Avoid expanding SOX scope to every security control merely because it is good practice.

Chapter 9 — Logical access governance

Define joiner, mover, leaver, privileged-access, service-account, emergency-access, and periodic-review controls for financially relevant systems. Link each access control to the risk it mitigates. Evidence should show request, approval, implementation, timely removal, reviewer decision, exceptions, and remediation. Generic IAM dashboards are supporting evidence only when they prove the relevant control population and period.

Chapter 10 — Segregation of duties and privileged access

Identify incompatible duties that could permit unauthorized financial transactions, configuration changes, journal activity, master-data changes, or concealment of errors. Where technical segregation is impractical, document compensating controls and test them. Privileged access should be limited, approved, monitored, periodically reviewed, and tied to named responsibilities.

Chapter 11 — Program change management

Require authorized requests, impact assessment, testing, approval, migration control, production access restrictions, and post-implementation evidence for financially relevant changes. Distinguish routine, standard, emergency, configuration, code, infrastructure-as-code, SaaS configuration, and vendor-managed changes. Emergency procedures should preserve traceability and retrospective approval.

Chapter 12 — Development, acquisition, and implementation

For new systems and major implementations, define requirements, control design, data conversion, interface validation, user acceptance testing, access design, segregation, cutover, rollback, and post-go-live monitoring. Evidence should demonstrate that financially relevant requirements were tested and that migration did not compromise completeness or accuracy.

Chapter 13 — Computer operations

Control scheduled jobs, batch processing, interfaces, backups, recovery, monitoring, failures, reruns, incident escalation, and operational changes. Evidence should demonstrate that exceptions are detected and resolved, not merely that monitoring tools exist. For cloud and SaaS services, identify which operational controls are retained by management and which depend on providers.

Chapter 14 — Interfaces and data transfers

Inventory financially significant inbound and outbound interfaces. Define control points for completeness, accuracy, authorization, reconciliation, error handling, rejected records, duplicate prevention, and change management. Automated transfer success alone does not prove financial completeness; reconcile source and destination populations where the risk requires it.

Chapter 15 — Reports and information produced by the entity (IPE)

Identify reports, queries, extracts, spreadsheets, dashboards, and calculations used in controls or financial reporting. Validate source data, parameters, logic, access, change history, and completeness/accuracy at a level appropriate to reliance. If a report is configurable, retain evidence of the exact parameters used for the control period.

Chapter 16 — Spreadsheets and end-user computing

Classify financially relevant spreadsheets and EUC tools by risk. Apply ownership, access restriction, version/change control, formula protection or review, input validation, reconciliation, backup, and independent review proportionate to risk. Track critical macros, scripts, low-code automations, and linked data sources as technology dependencies when they influence ICFR.

Chapter 17 — Control design effectiveness

Assess whether each control, if performed as designed by a competent owner at the stated frequency, would prevent or detect the identified financial-reporting risk in time. Document the control objective, trigger, population, performer, precision, evidence, dependencies, and escalation logic. A control can be well operated yet poorly designed if it does not address the risk with sufficient precision.

Chapter 18 — Operating effectiveness

Evaluate whether the control actually operated throughout the relevant period, by appropriate personnel, with consistent evidence and timely follow-up. Define the population and testing period before selecting items. Exceptions should be investigated for cause, duration, affected population, compensating activity, and possible impact on related controls.

Chapter 19 — Evidence design and retention

For every control, specify expected evidence, source system, owner, retention location, period covered, linkage to the control population, and reviewer attributes. Favor evidence generated as a natural result of the control rather than screenshots created only for audit. Preserve immutable or traceable records where practical and document any manual evidence assembly steps.

Chapter 20 — Population completeness and sampling readiness

Testing depends on a reliable population. Document how populations are generated, why they are complete, which filters were applied, and how duplicates, exclusions, or missing records are handled. Sampling approaches should be selected by competent reviewers based on the control, frequency, risk, population, and applicable audit methodology. This manual does not prescribe a universal sample size.

Chapter 21 — Service organizations and third parties

Map outsourced systems and services that affect ICFR. Identify complementary user-entity controls, subservice organizations, provider control reports, contract obligations, incidents, changes, and gaps. A SOC report or other assurance report is an input to management evaluation, not automatic proof that all relevant risks are controlled.

Chapter 22 — Cloud and SaaS considerations

Document the shared-responsibility model for financially relevant cloud services. Address tenant configuration, privileged access, identity federation, change processes, logging, backup/recovery, interfaces, provider changes, and evidence availability. Track configuration drift and significant service changes as reassessment triggers.

Chapter 23 — AI and automation in financially relevant processes

Where AI, machine learning, robotic process automation, or agentic automation influences financially relevant calculations, classifications, reconciliations, approvals, reports, or evidence, identify model/tool purpose, inputs, outputs, human oversight, change controls, access, validation, monitoring, fallback, and evidence. Do not assume AI-generated evidence is reliable without validation of provenance and completeness.

Chapter 24 — Deficiency identification and escalation

Record control failures, design gaps, evidence failures, recurring exceptions, and dependency failures in a structured deficiency process. Separate factual control findings from the legal/audit classification of a deficiency, significant deficiency, or material weakness. Escalate classification decisions to competent management and audit professionals using current SEC/PCAOB criteria and organization-specific facts.

Chapter 25 — Remediation planning

For each finding, identify root cause, affected control objective, impacted systems/processes, risk owner, corrective action, target date, interim control, evidence required, and retest criteria. Avoid closing findings merely because a technical change was deployed; verify that the redesigned control is operating and that related dependencies were addressed.

Chapter 26 — Retesting and closure

Retesting should confirm both remediation design and operation. Define a sufficient post-remediation observation period based on control frequency and risk. Retain the original finding, remediation evidence, retest evidence, reviewer conclusion, and closure approval. Reopen the issue if remediation introduces a new control gap or if operating evidence is insufficient.

Chapter 27 — Management certification support

Build a certification-support process that aggregates control status, significant changes, deficiencies, remediation status, disclosure-process inputs, and unresolved issues. Technology representations should be evidence-based and traceable to control owners and period-specific evidence. Escalation should occur before certification deadlines, not after evidence has been finalized.

Chapter 28 — External-auditor interaction

Maintain a controlled evidence handoff process with request tracking, ownership, due dates, version control, and issue escalation. Respond to auditor requests accurately without changing underlying evidence merely to fit the request. Track auditor observations separately from management's own deficiency evaluation until the responsible decision makers reconcile them.

Chapter 29 — Continuous monitoring and reassessment

Use dashboards, exception analytics, access recertification, change metrics, incident data, failed-job trends, control attestations, and remediation aging to identify deteriorating control performance. Monitoring does not replace control operation or independent testing. Define thresholds that trigger deeper review, scope reassessment, or control redesign.

Chapter 30 — Essential, Structured, and Enhanced implementation paths

Essential organizations establish a defensible scope, core ITGC inventory, ownership, evidence, and deficiency process. Structured organizations add formal risk/assertion linkage, population controls, standardized testing, service-provider governance, and integrated remediation. Enhanced organizations add continuous monitoring, automated evidence provenance, configuration analytics, cross-system lineage, and change-triggered reassessment. Maturity does not change legal obligations; it changes the reliability and efficiency of control execution.

Chapter 31 — Common failure modes and practitioner scenarios

Common failures include over-scoping generic cybersecurity controls, relying on screenshots without population evidence, treating SOC reports as automatic assurance, weak IPE validation, unresolved privileged access, emergency changes without retrospective review, spreadsheet drift, incomplete interface monitoring, and remediation closure without retesting. Use scenario exercises to test whether practitioners can identify the ICFR risk, required evidence, escalation route, and affected dependencies.

Chapter 32 — Final release and operating checklist

Before using this manual as an operational baseline, verify current SOX/SEC/PCAOB source status, scope, ownership, control-to-risk traceability, evidence design, localization fidelity, accessibility, provenance, and change history. For repository publication, require the exact candidate hash, trilingual source hashes, DOCX/PDF hashes, QA results, source verification record, review evidence, checksums, manifest, workflow security, predecessor publication, catalog/release-registry reconciliation, and standing release authorization. Any material change after review reopens only affected gates.

Practitioner evidence and testing appendix

Manual 13 Practitioner Evidence and Testing Appendix

A. Control-to-risk worksheet

For every financially relevant technology control, record the financial-reporting risk, relevant process/account/disclosure, affected assertion or objective, system or data dependency, control owner, performer, frequency, evidence source, evidence retention location, control dependencies, exception path, and reassessment trigger. The worksheet should make it possible for a reviewer who did not design the control to understand why the control is in ICFR scope and how its failure could affect financial reporting.

A complete record should answer: What risk is being addressed? What event starts the control? What population is subject to the control? Who performs and reviews it? What evidence proves operation? How precise is the review? What happens when an exception is found? Which upstream or downstream controls depend on it? What change would require the control to be redesigned or retested?

B. Access-control evidence pattern

For user access, retain request and approval evidence, role or entitlement granted, implementation timestamp, identity of the administrator, source-system record, periodic review decision, and any remediation. For privileged access, include business justification, time or scope limits where applicable, monitoring evidence, and recertification. For terminated users, demonstrate the population source and timeliness of removal rather than presenting a few screenshots without proof of completeness.

A reviewer should be able to reconcile the tested population to a reliable employee/contractor source, identify excluded identities and service accounts, and explain whether access inherited through groups, roles, federation, or application-specific permissions is included. Exceptions should be classified by cause and potential financial-reporting impact before remediation is closed.

C. Change-management evidence pattern

For financially relevant changes, retain the approved request, risk/impact assessment, requirements or change description, test evidence, segregation between developer and production migration where required, approval to migrate, deployment record, rollback plan where relevant, and post-implementation validation. Emergency changes require a documented emergency basis and retrospective review within the organization's defined timeframe.

For SaaS and low-code platforms, configuration changes may be as significant as source-code releases. Preserve audit trails, configuration snapshots, approval records, and evidence that changes to workflows, formulas, permissions, integrations, or reporting logic were evaluated for ICFR impact.

D. Computer-operations evidence pattern

For scheduled processing, identify the expected job population, monitoring method, failure criteria, notification route, restart/rerun authority, reconciliation steps, and evidence of resolution. A successful scheduler status may be insufficient when financial completeness depends on record counts, control totals, interface acknowledgements, or downstream reconciliation.

Backup evidence should be evaluated in the context of the financial-reporting dependency. Demonstrating that backups run is different from demonstrating that critical financial data can be restored within needed recovery objectives. Where recovery controls support ICFR, retain test results, exceptions, remediation, and management review.

E. Interface and reconciliation evidence pattern

For each material interface, document source and destination, frequency, record or value population, transfer mechanism, automated checks, rejected-record handling, duplicate prevention, reconciliation logic, thresholds, and ownership. Evidence should show both transmission and integrity where the financial-reporting risk requires it.

When a reconciliation is manual, define reviewer precision and escalation thresholds. When it is automated, identify the code/configuration, change controls, input completeness, error handling, and monitoring. If the interface is provider-managed, identify which control evidence is available from the provider and which controls remain the organization's responsibility.

F. IPE and report-reliance evidence pattern

When a control relies on a system-generated report or query, preserve evidence that the report is complete and accurate for the intended purpose. Record report name, system, owner, parameters, period, filters, data source, logic, and access restrictions. If report logic can change, identify the applicable change-control evidence.

For ad hoc queries or scripts, retain the exact query/script used and evidence of review. For dashboards, preserve the filters and date ranges used by the control performer. For spreadsheets, identify source data, formulas/macros, version, access, review, and reconciliation. A report title and screenshot are not sufficient when the underlying population cannot be reproduced.

G. Service-organization reliance worksheet

For each service organization affecting ICFR, document the service, financially relevant processes/systems, report or assurance evidence reviewed, period covered, complementary user-entity controls, subservice organizations, exceptions, bridge-period considerations, incidents, and management conclusion. Do not equate receipt of a SOC report with automatic reliance.

Management should evaluate whether the report's scope, system description, control objectives/criteria, period, auditor opinion, exceptions, and subservice treatment address the organization's actual dependency. Unaddressed gaps require additional controls, alternative evidence, or risk acceptance/escalation by competent management.

H. Testing workpaper minimums

A management testing workpaper should identify control ID, objective, risk, control description, owner, frequency, population source, period, test method, sample rationale where applicable, items tested, evidence examined, exceptions, conclusion, reviewer, review date, and follow-up. Separate design assessment from operating-effectiveness testing so a failure in one dimension is visible.

Testing should be reproducible. Another competent reviewer should be able to understand how the population was obtained, why selected items were tested, what evidence supported each attribute, and why the conclusion follows from the evidence. Unsupported statements such as "control operating effectively" are not sufficient workpaper evidence.

I. Deficiency and remediation worksheet

Record the factual condition, control objective, affected process/system, duration, population potentially affected, compensating controls, root cause, immediate containment, corrective action, owner, due date, evidence required for closure, and retest plan. Keep factual observations separate from the ultimate significant-deficiency/material-weakness classification.

When multiple control failures share a common cause, evaluate them collectively. When a deficiency spans periods or systems, document how the affected population was bounded. Remediation closure should include evidence of implemented design and evidence of operation for a period appropriate to control frequency and risk.

J. Change-triggered reassessment checklist

Reassess scope and control design after significant system implementation, ERP migration, acquisition/divestiture, cloud migration, major identity-platform change, outsourcing, finance-process redesign, new interface, material incident, repeated control exception, introduction of financially relevant AI/automation, or a change in authoritative requirements.

The reassessment record should identify the triggering event, affected accounts/processes/systems, changed risks, controls added/removed/modified, evidence impacts, testing required, and whether prior review evidence remains applicable. Material changes after publication-review freeze reopen only affected gates, but the affected scope must be bounded confidently.

K. Practitioner scenario — privileged-access exception

A finance administrator receives elevated access to resolve a production issue and retains the role beyond the approved emergency window. The organization should identify the affected financial systems and capabilities, determine whether conflicting activities occurred, inspect logs and transactions as needed, remove or correct the access, assess related monitoring controls, record the exception, and determine whether broader population testing is required. Classification of the control issue remains a competent management/audit judgment.

L. Practitioner scenario — report parameter error

A monthly reconciliation control uses a report generated with an incorrect date filter for two periods. The response should identify the affected reconciliations, reproduce the correct populations, assess whether errors could have been missed, determine whether other controls detected the issue, correct the report procedure or configuration, retest the control, and evaluate the deficiency using current authoritative criteria and organization-specific facts.

M. Practitioner scenario — SaaS configuration change

A vendor changes a configurable financial workflow after a platform update. The organization should determine whether the change affected approval routing, access, calculation logic, interfaces, or evidence. It should obtain available provider information, compare tenant configuration, test the financially relevant workflow, update change/control documentation, and reassess any related service-organization reliance.

N. Practitioner scenario — AI-assisted financial process

An AI-enabled tool proposes account classifications used in a financial close process. Controls should address approved use, input provenance, output review, model/tool changes, access, fallback, monitoring, exception handling, and evidence. Management should not assume that model confidence scores prove financial accuracy. The control design must specify how human reviewers validate results and how material anomalies are escalated.

O. Release evidence checklist

A publication-ready Manual 13 package should contain exact controlled-source identity, authoritative-source verification evidence, trilingual source identity, generated DOCX/PDF artifacts, page-level QA results, accessibility/visual review evidence, artifact checksums, release manifest, workflow-security results, changed-scope reconciliation, and the applicable review decisions tied to the exact candidate and artifact hashes. Standing final release authorization is already established separately; no additional owner approval should be requested once all other required gates are genuinely green.